

OS Command Injection

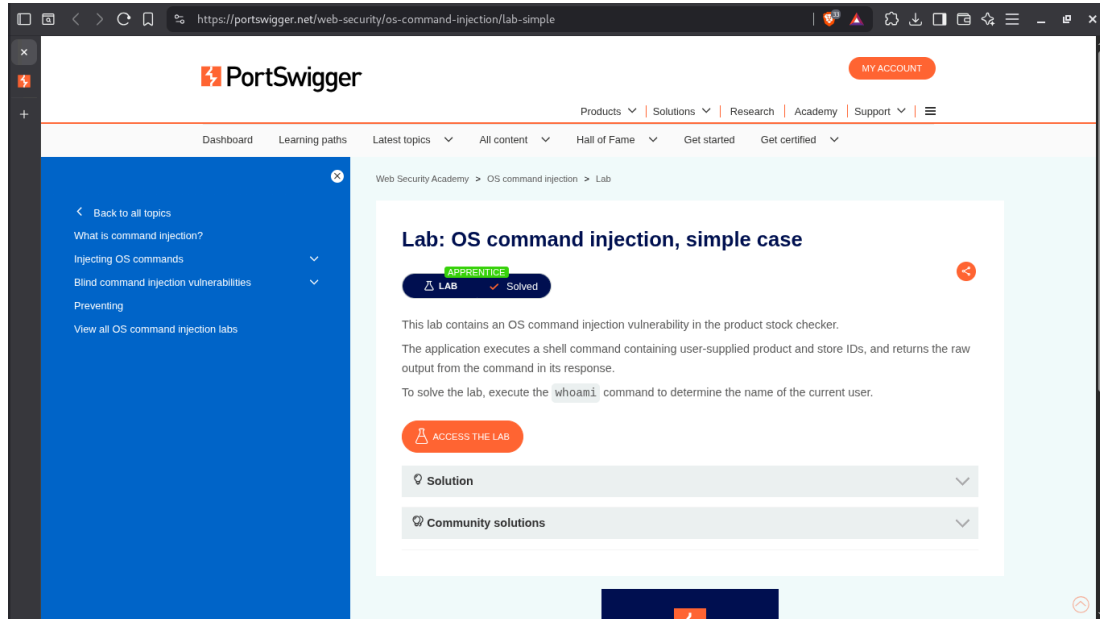
Name: Matyas Abreham

IDNO: CTC-207-26

Lab 5: OS Command Injection, Simple Case

Objective

Execute the whoami command via the product stock checker to determine the name of the current user.

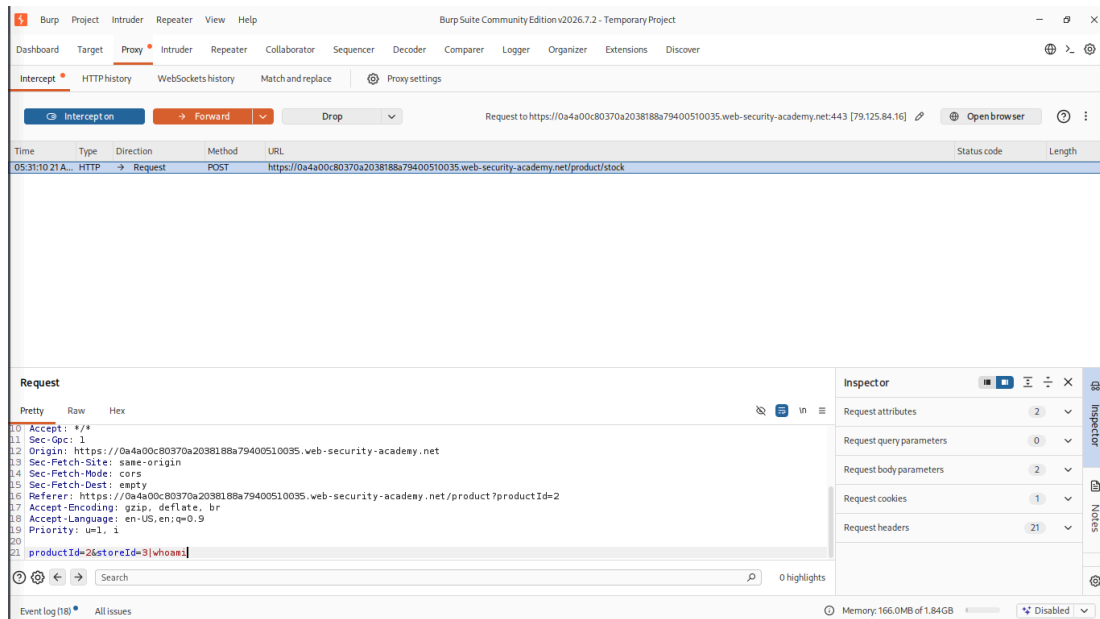


Lab description page (PortSwigger).

Steps

- Used the "Check stock" feature on a product page, which sends a POST request to /product/stock.
- Intercepted the request in Burp Suite and appended a shell command using a pipe operator.

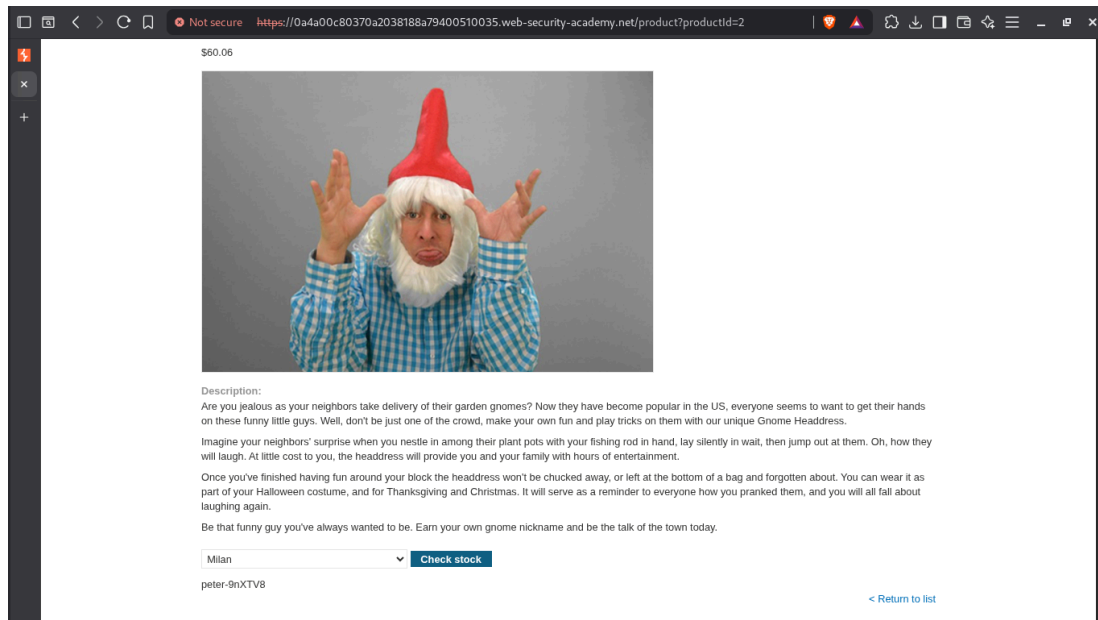
productId=2&storeId=3|whoami



Burp Proxy intercepting the request with the injected command.

Result

The response included the output of the whoami command: peter-9nXTV8



Command output (username) returned on the product page.



Lab marked as Solved.

Vulnerability

The storeId parameter was passed directly into a shell command without sanitization, allowing arbitrary command execution via the | operator.